

SAM10 INFRASTRUCTURE DESIGN DOCUMENT

Comprehensive AWS Cloud Blueprint for MediCare Direct Clinic Management System

Student Name: Robert Angel B. Santiago	Course & Section: SAM10 / BSIT-4-A
Student ID: 23-1360-266	Instructor: Romack L. Natividad, MIT
System Name: MediCare Direct	Target AWS Region: ap-southeast-1 (Singapore)

SECTION A: SYSTEM OVERVIEW & WORKLOAD ANALYSIS

System Purpose & Business Concept (~120 Words): MediCare Direct is an enterprise outpatient clinic and appointment management system designed to digitize healthcare workflows, physician schedule tracking, and patient health record access. The platform serves three core user groups: (1) *Patients* accessing the public web portal to schedule appointments, view consultation slots, and track queue statuses; (2) *Healthcare Providers and Clinic Staff* managing patient rosters, documenting consultation notes, and updating electronic health records (EHR); and (3) *Cloud Administrators* overseeing network availability, automated backup retention, and strict compliance with health data privacy regulations.

System Workloads & Requirements Mapping: To ensure clinical availability and privacy, MediCare Direct decouples public presentation from sensitive health record processing. The web tier handles SSL/TLS termination, the application tier processes scheduling business logic, and the database tier persists encrypted patient records within an isolated data network.

SECTION B: VPC & SUBNET DESIGN

CIDR Allocation & Topology Strategy: The infrastructure is provisioned in the **ap-southeast-1 (Singapore)** region inside a dedicated Virtual Private Cloud (VPC) with a primary CIDR block of **10.0.0.0/16**, providing 65,536 private IP addresses. Network isolation is achieved by partitioning the VPC into three distinct /24 subnets (251 usable host IPs each), isolating workloads by security boundary and operational role.

Subnet Isolation Justification: Logical network segmentation prevents lateral movement during potential security incidents. If a public-facing web server is compromised, network routing boundaries prevent direct access to application logic or persistent database storage in private subnets.

Subnet Name	CIDR Block	Subnet Type	Hosted Components & Network Boundary Role
Public Subnet	10.0.1.0/24	Public Tier	Hosts Web EC2 (t3.micro), NGINX reverse proxy, IGW Route (0.0.0.0/0 -> IGW).
Private App Subnet	10.0.2.0/24	Private Tier	Hosts Application EC2 (t3.small), Node.js Express API. Isolated from direct IGW routes.
Private Data Subnet	10.0.3.0/24	Private Tier	Hosts Database EC2 (t3.small), PostgreSQL 15, KMS-encrypted EBS volumes. Local VPC route only.

Multi-AZ Expansion Readiness: The CIDR block layout explicitly reserves 10.0.10.0/24, 10.0.20.0/24, and 10.0.30.0/24 for secondary Availability Zone (ap-southeast-1b) deployment in Phase 2, enabling seamless multi-AZ load balancing without re-IPing hosts.

SECTION C: NETWORK & ROUTING DESIGN

Route Table & Gateway Architecture: An Internet Gateway (IGW) is attached to the VPC boundary to allow controlled bidirectional public Internet traffic. Traffic routing is managed via two explicit route tables:

- **Public Route Table:** Contains a default route entry (0.0.0.0/0 -> IGW) alongside the local VPC route (10.0.0.0/16 -> local). Associated strictly with Public Subnet (10.0.1.0/24).
- **Private Route Table:** Contains only the local VPC route (10.0.0.0/16 -> local) with no default route to the IGW, enforcing strict Internet isolation for the App and Data subnets.

Step-by-Step Directional Traffic Flow:

1. **Public Patient Ingress:** Internet users initiate encrypted HTTPS connections on Port 443 through the IGW to the Web Server in the Public Subnet.
2. **Application Forwarding:** The NGINX proxy validates incoming web requests and forwards verified API payloads to the Application Server on Port 5000 inside the Private App Subnet.
3. **Database Query Execution:** The Application API executes SQL queries against the PostgreSQL Database Server on Port 5432 in the Private Data Subnet.
4. **Egress Restrictions:** Private instances cannot initiate direct Internet connections, preventing unauthorized data exfiltration.

SECTION D: COMPUTE & STORAGE DESIGN

Compute Sizing & Workload Specifications: All workloads run on Amazon EC2 instances powered by Amazon Linux 2023, offering a secure, lightweight, and AWS-optimized operating system.

Compute Role	Instance Sizing	OS & Software Runtime	EBS Capacity	Subnet Placement & Purpose
Web Server	t3.micro (2 vCPU, 1GB RAM)	Amazon Linux 2023 / NGINX	20 GB gp3	Public Subnet (10.0.1.0/24) - Public web portal & SSL termination.
App Server	t3.small (2 vCPU, 2GB RAM)	Amazon Linux 2023 / Node.js	30 GB gp3	Private App Subnet (10.0.2.0/24) - REST API scheduling engine.
Database Server	t3.small (2 vCPU, 2GB RAM)	Amazon Linux 2023 / PostgreSQL 15	100 GB gp3	Private Data Subnet (10.0.3.0/24) - Encrypted clinical database.

EC2 vs. Serverless Architectural Comparison:

EC2 instances were specifically chosen over AWS Lambda or Elastic Beanstalk. While serverless functions provide auto-scaling, EC2 provides complete operating system access necessary for custom security hardening, fine-grained PostgreSQL kernel tuning, compliance audit logging, and fixed 24/7 baseline cost predictability without cold-start latency issues.

Storage, KMS Encryption & Backup Strategy:

- **EBS Volume Specification:** Workloads use General Purpose SSD (gp3) volumes providing a baseline performance of 3,000 IOPS and 125 MB/s throughput, independent of volume size.
- **Encryption at Rest:** The Database EBS volume (100 GB) is encrypted using AWS Key Management Service (KMS) with an AWS-managed customer master key (AES-256 encryption standard).
- **AWS Backup Lifecycle:** Automated daily snapshots are managed via AWS Backup with a 30-day retention policy and automated cold-storage archiving after 14 days.
- **Administrative Access:** Direct SSH Port 22 is disabled across all instances. Administrators securely manage instances via **AWS Systems Manager (SSM) Session Manager**, eliminating bastion host requirements.

SECTION E: SECURITY GROUP & IAM DESIGN

Security Group Least Privilege Firewall Matrix: Inbound network access is controlled via stateful Security Group rules utilizing Security Group ID chaining to enforce strict origin validation.

Security Group	Port / Protocol	Traffic Source / Origin	Architectural Security Rationale
sg-WebTier	Port 80 (HTTP) Port 443 (HTTPS)	0.0.0.0/0 (Public Internet)	Allows public patient web access; HTTP traffic redirects to HTTPS.
sg-AppTier	Port 5000 (TCP)	sg-WebTier (Security Group ID)	Restricts API access strictly to authorized Web Tier proxy instances.
sg-DBTier	Port 5432 (PostgreSQL)	sg-AppTier (Security Group ID)	Restricts clinical database access strictly to Application API instances.

IAM Role Governance & Least Privilege Access: Daily administrative access is governed via Role-Based Access Control (RBAC). The AWS Root Account is protected with hardware MFA and locked down for break-glass emergency billing tasks only.



Figure 2: IAM Role-Based Access Control (RBAC) Governance Structure & MFA Boundaries.

SECTION F: COST ESTIMATION & OPTIMIZATION

Reproducible Cost Calculation (Pricing Date: Sept 2026, Region: ap-southeast-1): Calculated for 730 monthly operating hours using standard AWS pricing models. The total baseline cost is **\$75.98 / month (\$911.76 / year)**.

AWS Service Component	Configuration & Pricing Assumptions	Qty / Operating Hours	Monthly Cost (\$)
EC2 Web Instance	t3.micro On-Demand (\$0.0144/hr) - Linux	1 instance (730 hrs)	\$10.51
EC2 App Instance	t3.small On-Demand (\$0.0288/hr) - Linux	1 instance (730 hrs)	\$21.02
EC2 DB Instance	t3.small On-Demand (\$0.0288/hr) - Linux	1 instance (730 hrs)	\$21.02
EBS gp3 Storage	150 GB total capacity (\$0.092/GB-month)	150 GB-month	\$13.80
Public IPv4 Address	In-use Public IPv4 (\$0.005/hr)	730 hours	\$3.65
EBS Snapshots / Backup	AWS Backup Snapshot Storage (\$0.05/GB)	50 GB-month	\$2.50
CloudWatch & Data Transfer	Logs (2 GB) + Data Out (15 GB)	Standard Usage	\$3.48
TOTAL ESTIMATED COST	AWS Region: ap-southeast-1 (Singapore)	Monthly Total	\$75.98 / mo

Cost Optimization Strategies: (1) Purchasing a **1-Year Compute Savings Plan** cuts EC2 instance runtime costs by up to 34% (~\$17.80/mo savings); (2) Configuring **AWS Lifecycle Manager** to automatically purge EBS snapshots older than 30 days prevents storage cost accumulation.

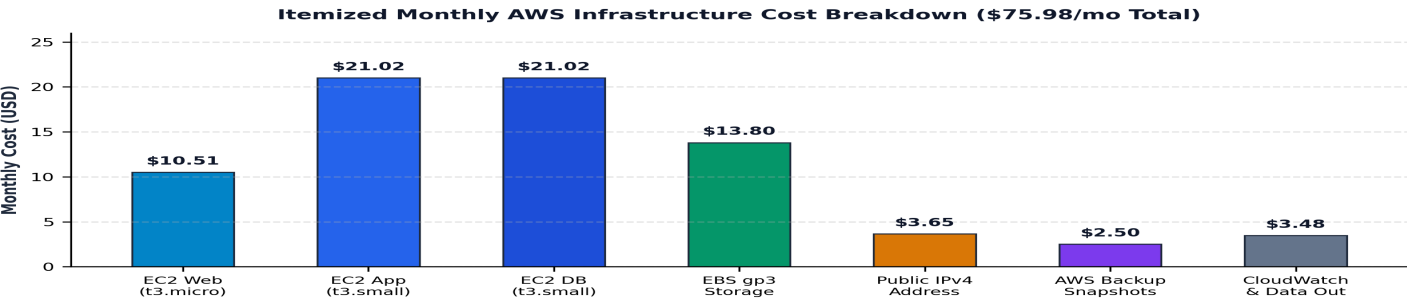


Figure 3: Itemized Monthly AWS Infrastructure Cost Distribution for MediCare Direct.

SECTION G: EXPLANATION OF MAJOR DESIGN DECISIONS

The proposed infrastructure strictly aligns with the 5 AWS Architectural Lenses specified in the project guidelines:

1. **Segmentation:** Decouples the public web front-end from application logic and sensitive clinical database storage across isolated CIDR subnets, ensuring that external web vulnerabilities do not compromise patient medical records.
2. **Least Privilege:** Enforces stateful firewall chaining where the database tier accepts traffic exclusively on Port 5432 from the App Security Group ID. Administrative SSH Port 22 is closed in favor of IAM-authenticated SSM Session Manager.
3. **Controlled Connectivity:** Public ingress is restricted to HTTP/HTTPS via an Internet Gateway. Internal traffic follows unidirectional route table rules with zero direct Internet access from private subnets.
4. **Scalability:** Subnet allocations (/24 CIDRs) reserve over 250 available host addresses per tier, supporting future horizontal scaling with Auto Scaling Groups and Application Load Balancers (ALB) without rearchitecting the network.
5. **Simplicity:** Omits unnecessary managed service bloat, maintaining a lean, highly manageable, and cost-effective cloud foundation (\$75.98/mo) ideal for Phase 2 deployment.

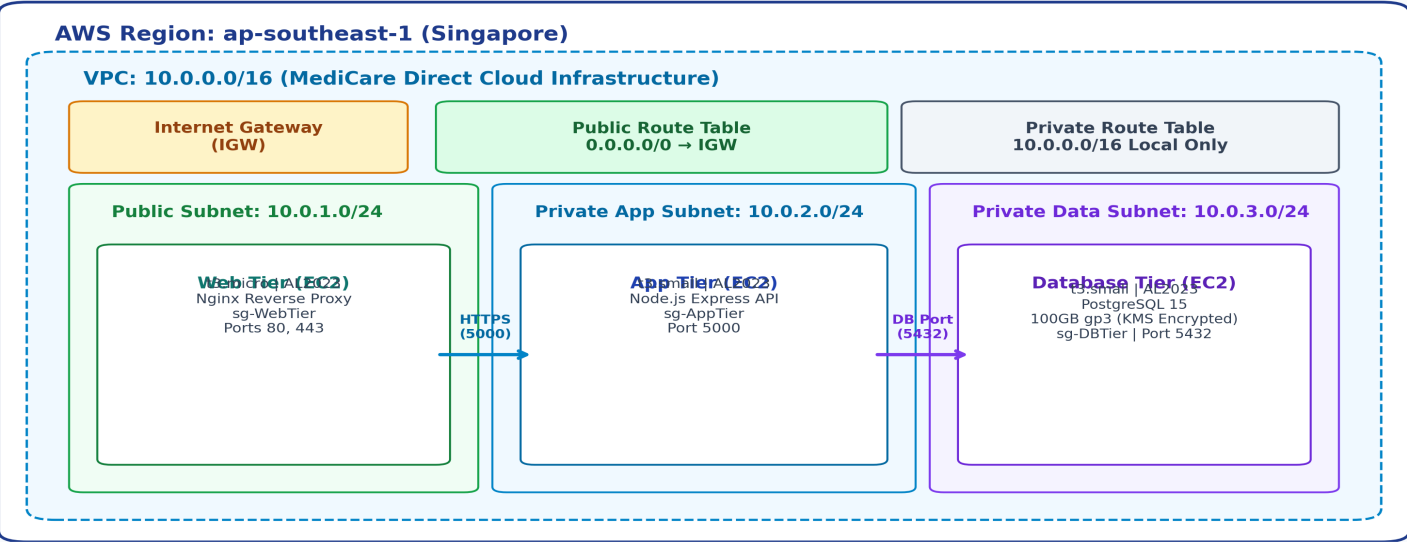


Figure 1: Complete AWS 3-Tier Cloud Architecture Blueprint for MediCare Direct System.

PROJECT SIGN-OFF & SUBMISSION APPROVAL

Submitted By:	Robert Angel B. Santiago (Student ID: 23-1360-266 BSIT-4-A)
Submitted To:	Romack L. Natividad, MIT (Instructor, SAM10 Systems Admin)
Institution:	Angeles University Foundation — College of Computer Studies (AUF CCS)
Platform & Phase:	AUF Canvas Instructure LMS Phase 1: Infrastructure Design Blueprint